

ASISTENTE DE CIBERSEGURIDAD Y COMPLIANCE CON IA

Ex-1234 | Trabajo Fin de Curso | IMPACT#include13 | 07/06/2026

Contenido

1. Arquitectura del asistente	3
2. Diagramas de flujo	4
2.1. Diagrama de flujo del RAG	4
2.2. Diagrama de flujo del agente	5
2.2.1. Entrada y portero.....	7
2.2.2. Motor de cortesía	8
2.2.3. Auditor de adjuntos.....	9
2.2.4. Motor de preguntas y respuestas	11
3. Limitaciones y problemas encontrados	12
3.1. Disponibilidad de normativas	12
3.2. Limitaciones del hardware	12
3.3. Limitaciones de los LLM	12
3.3.1. Limitaciones de llama.....	12
3.3.2. Limitaciones de qwen.....	12
3.3.3. Veredicto	12
4. Pruebas de funcionamiento.....	13
4.1. Análisis de políticas de seguridad (A MEDIAS).....	13
4.2. Detección de riesgos e incumplimientos (A MEDIAS)	14
4.3. Respuesta a preguntas de auditoría (FALLA).....	15
4.4. Propuestas de mejora (A MEDIAS)	15
5. Conclusiones.....	16
ANEXO I: Prompts	17

1. Arquitectura del asistente

Capa	Tecnología usada	Función
Entrada	n8n (local)	El usuario sube documentos y escribe preguntas en el chat.
Gestión documental	Google Drive	Se almacenan todas las normativas aquí.
Base de conocimiento (RAG)	Qdrant + nomic-embed-text (local)	nomic-embed-text vectoriza las normativas y las almacena en una base de datos Qdrant.
Orquestación	n8n (local)	Recibe la pregunta, recupera contexto del RAG, llama al LLM y devuelve la respuesta.
Modelo LLM	llama3.1:8b (local)	Genera las respuestas en función de la entrada.
Salida	n8n (local)	El usuario recibe una respuesta del agente por el mismo chat.

Se eligió su despliegue en local (con la excepción de la gestión documental en Google Drive) con el propósito de no tener que lidiar con cuotas de uso y límite de tokens.

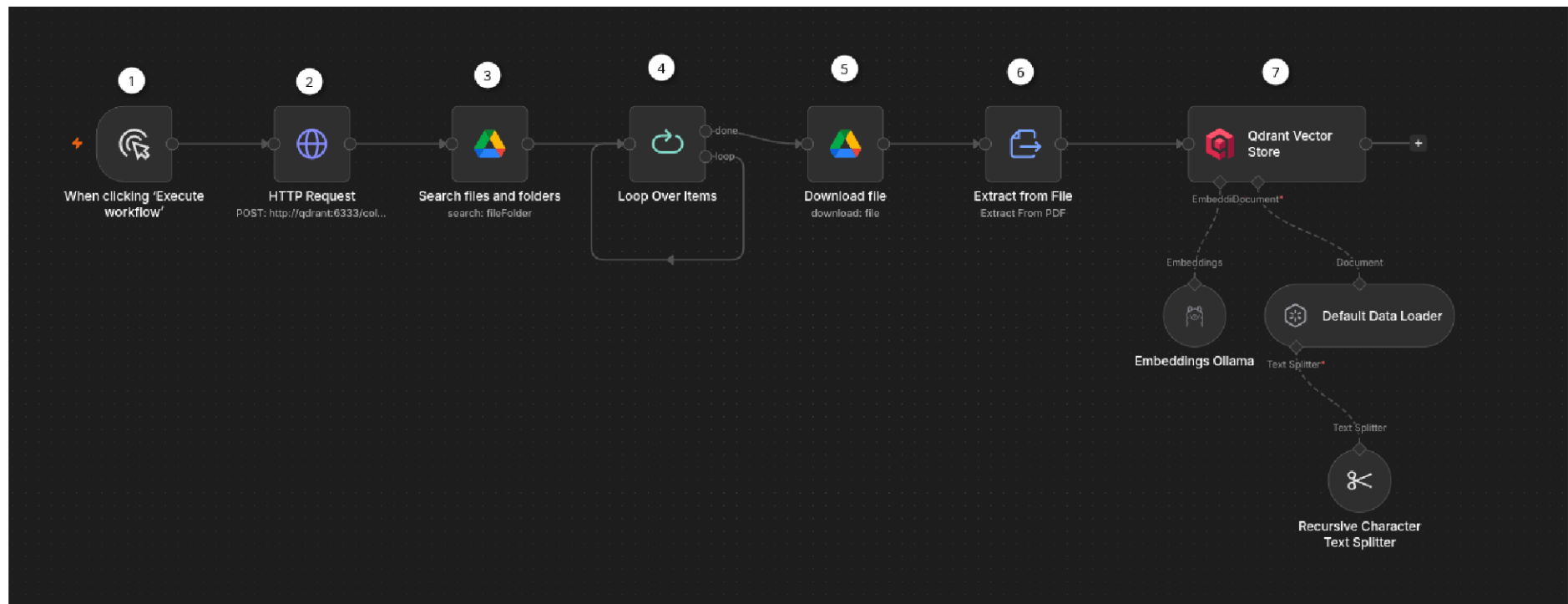
El gestor de modelos LLM es ollama. Desde él se descargaron y utilizaron los modelos llama3.1, nomic-embed-text y qwen2.5.

2. Diagramas de flujo

El funcionamiento del agente está dividido en dos flujos: el RAG y el agente propiamente dicho.

2.1. Diagrama de flujo del RAG

Este es el diagrama de flujo del RAG completo.

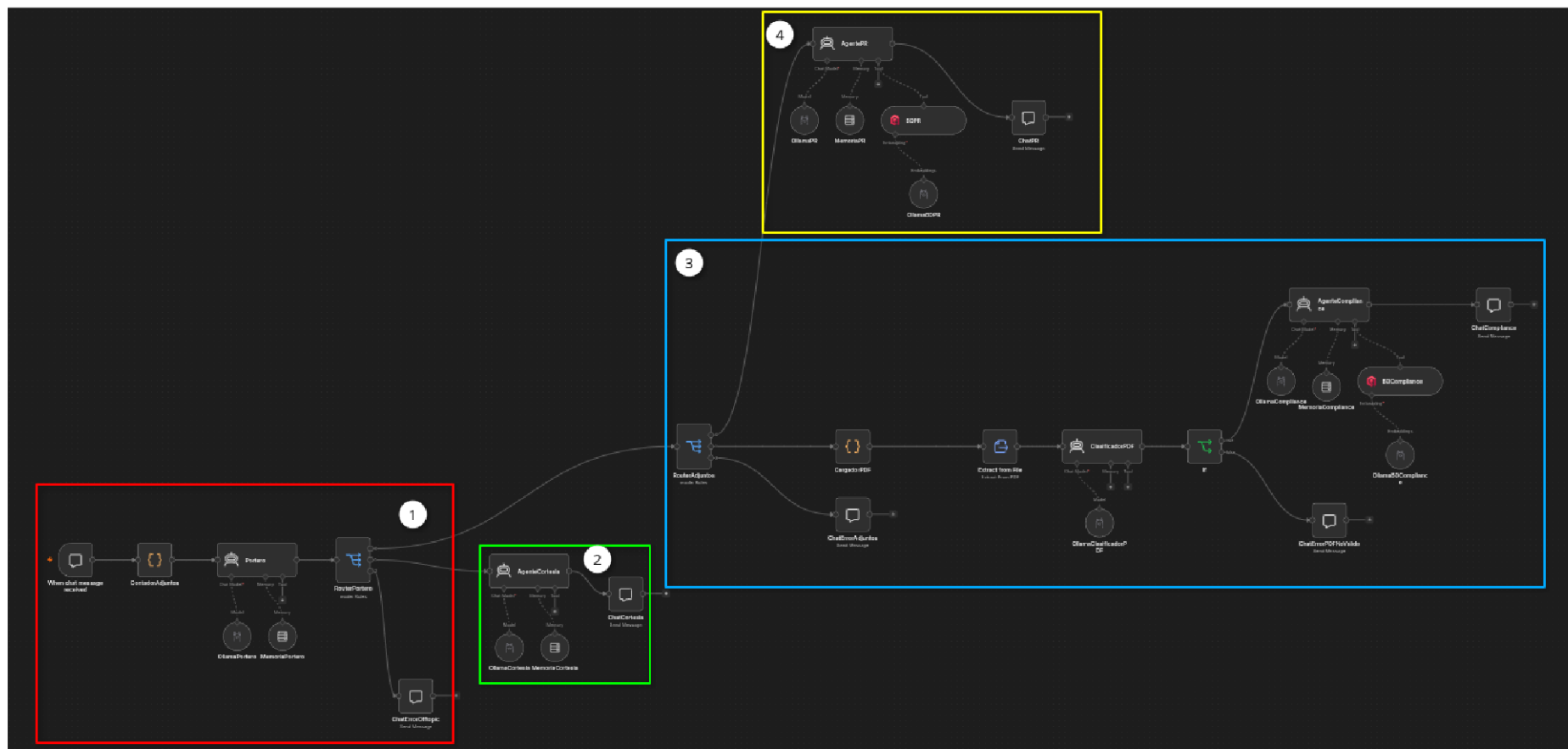


A continuación, explicaré qué hace cada uno de los nodos señalados en el flujo.

1. Nodo activador: cuando se pulsa el botón de “Execute workflow” comenzará el proceso de ingesta y vectorización de las normativas.
2. Petición a la API: esta petición a la API vaciará el vector para evitar duplicados. Es una medida de seguridad para evitar redundancia de datos en la base de datos.
3. Conexión con Google Drive: este nodo se conectará a una carpeta de Google Drive y listará todos los archivos que hay en ella. Actualmente sólo tiene dos archivos: el Esquema Nacional de Seguridad (ENS) y el Reglamento General de Protección de Datos (RGPD). No obstante, el funcionamiento del agente es totalmente agnóstico y permite la carga de cualquier documento para ampliar su base de conocimiento.
4. Iterador: este nodo hará una iteración por cada uno de los archivos que hay en la carpeta de Drive.
5. Descarga desde Drive: este nodo descarga los documentos subidos a Drive que hay en la carpeta de trabajo.
6. Extractor de PDF: este nodo extrae los datos de cada uno de los archivos PDF y los convierte a JSON.
7. Base de datos Qdrant: Este nodo procesa, trocea y vectoriza el JSON de entrada y lo sube los datos a la base de datos.

2.2. Diagrama de flujo del agente

Este diagrama de flujo es muchísimo más extenso, por lo que daré una vista general del mismo y lo dividiré en varios cuadrantes con una función específica. La idea es tener una visión general del flujo y luego una más detallada.



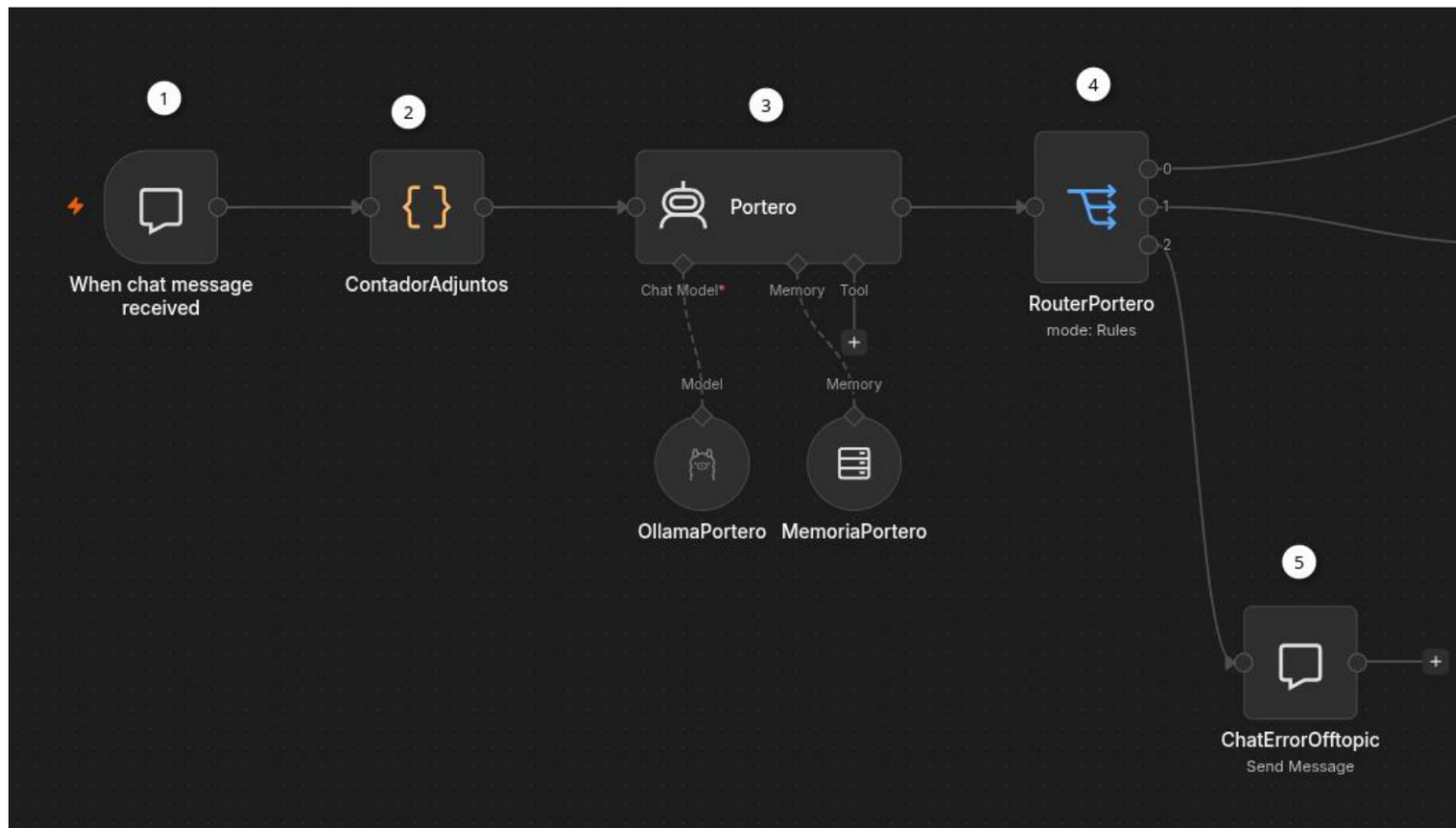
Los cuatro cuadrantes son los siguientes:

1. Entrada y portero.
2. Motor de cortesía.
3. Auditor de adjuntos.

4. Motor de preguntas y respuestas.

A continuación, entraré en más detalle explicando qué hace cada cuadrante.

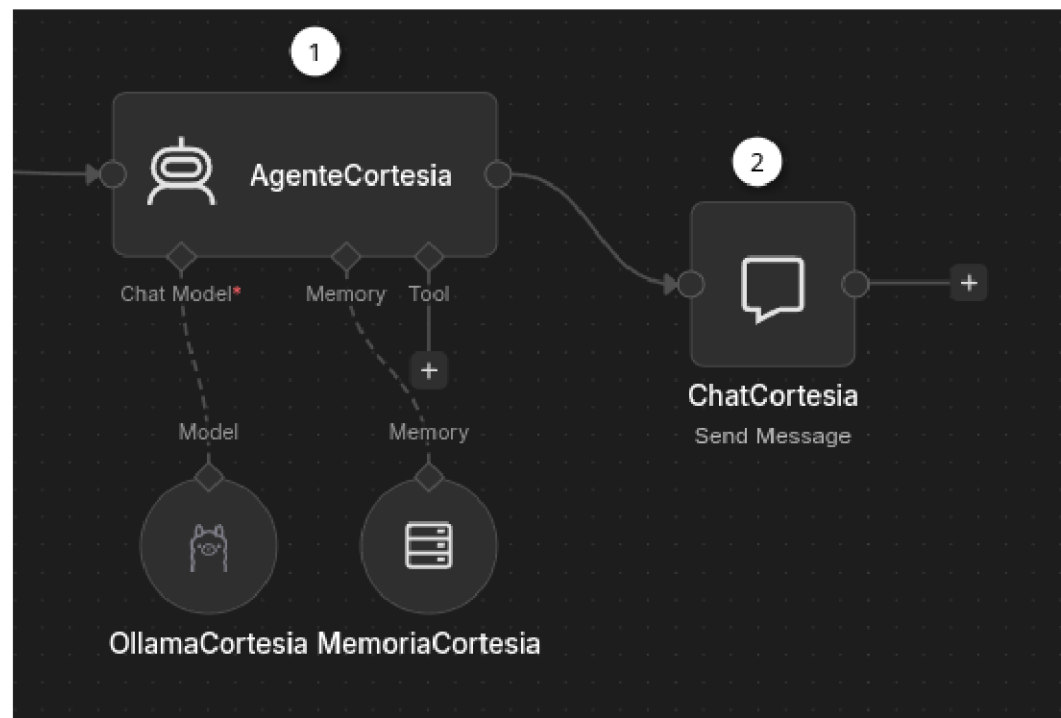
2.2.1. Entrada y portero



Este es el cuadrante del punto de entrada y el portero. Sus nodos son los siguientes:

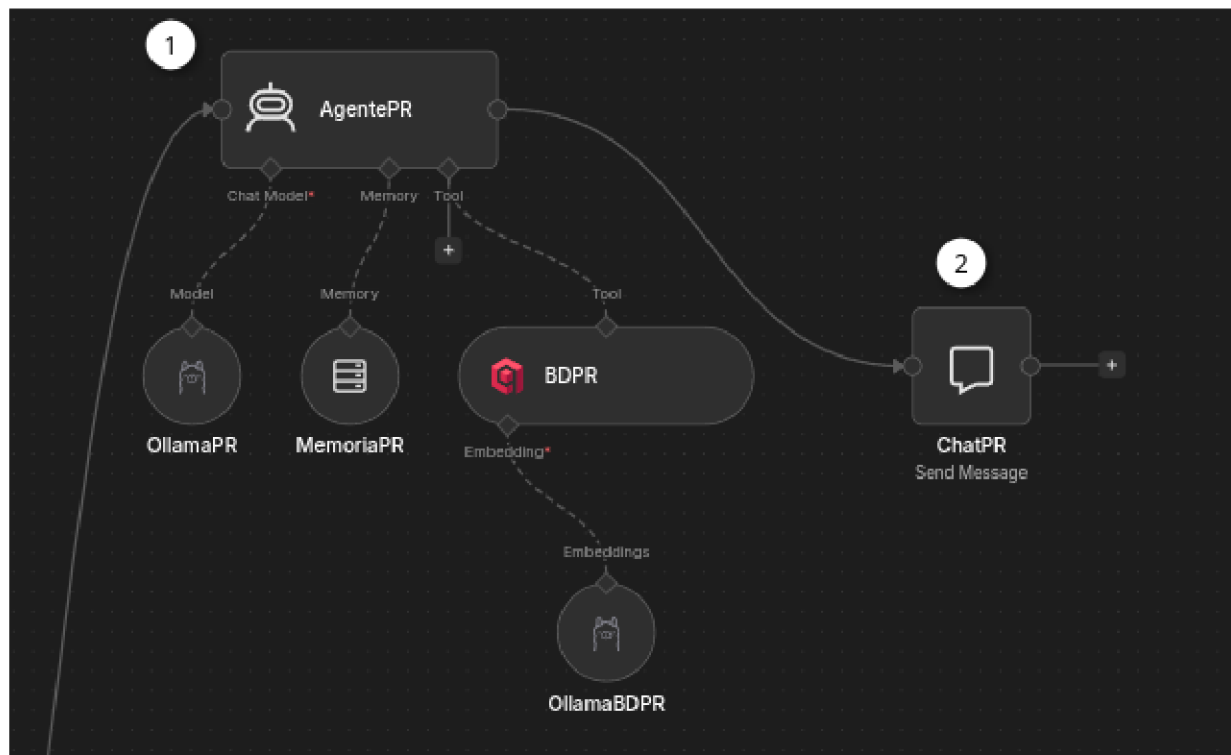
1. Disparador: Este nodo inicia todo el flujo cuando recibe un mensaje de chat en n8n.
2. Función contadora: Esta función en JavaScript cuenta el número de adjuntos que tiene el mensaje, necesario para más tarde.
3. Portero: Pequeño agente de IA que clasifica los mensajes recibidos en tres grandes grupos:
 - a. Procedente: mensajes que entran dentro del *scope* del agente (auditoría, consultas sobre ciberseguridad, etc.)
 - b. Cortesía: saludos, despedidas y agradecimientos.
 - c. Rechazado: mensajes que no entran dentro del *scope* del agente.
4. Enrutador del portero: Cláusula switch que encauza el flujo según la clasificación anterior.
5. Mensaje de error para los mensajes rechazados.

2.2.2. Motor de cortesía



1. Enrutador de adjuntos: Cláusula switch que encauza el flujo dependiendo del número de adjuntos que haya en el mensaje del chat. Referencia a la función contadora de la entrada.
 - a. Si no hay ninguno, lo manda al motor de preguntas y respuestas.
 - b. Si sólo hay uno, pasa al punto 2.
 - c. Si hay más de uno, pasa al punto 3.
2. Cargador de PDF: Carga el PDF adjunto en el chat.
3. Mensaje de error: Si hay más de un PDF adjunto lanzará un mensaje de error.
4. Extractor de texto: Extrae el texto del PDF y lo almacena en un JSON.
5. Clasificador de PDF: Pequeño agente de IA que determina si el PDF es relevante (es efectivamente un documento de políticas de seguridad) o no (es cualquier otra cosa).
6. Cláusula if: Ramificación de ejecución que depende de la salida del clasificador de PDF.
 - a. La rama true quiere decir que el PDF es relevante.
 - b. La rama false quiere decir que el PDF es irrelevante.
7. Agente Compliance: motor de IA que cruza los datos del PDF de entrada (en este caso, el de políticas de seguridad de Midtech) con las normativas en la base de conocimiento. Totalmente agnóstico al contenido.
8. Mensaje de error: Si el PDF es irrelevante lanzará un mensaje de error.
9. Salida de chat: Salida de chat del Agente Compliance.

2.2.4. Motor de preguntas y respuestas



Este es el cuadrante del motor de preguntas y respuestas sobre normativa. Sus nodos son los siguientes:

1. AgentePR: Agente de IA dedicado a responder preguntas sobre normativa. Utiliza exclusivamente los datos vectorizados en su base de datos. Totalmente agnóstico al contenido.
2. Salida de chat: Salida de chat del agente de IA.

3. Limitaciones y problemas encontrados

3.1. Disponibilidad de normativas

De las tres normativas que se pedían no he podido adjuntar una de ellas, la ISO 27001 debido a que es de pago, su alto coste y que las versiones que he logrado encontrar por ahí eran muy incompletas, algo inaceptable.

No obstante, debido a la agnosticidad del agente, es posible añadirle las normativas que sean necesarias, únicamente siendo necesario el prerequisite de añadirle a los archivos como metadatos las palabras clave con exiftool.

Ejemplo: Para el RGPD las palabras clave fueron las siguientes: “reglamento general de proteccion de datos, reglamento, general, proteccion, datos, rgpd, gdpr”

3.2. Limitaciones del hardware

Debido a que los servicios LLM en la nube tienen muchas limitaciones en sus versiones gratuitas se decidió utilizar mi ordenador como estación de trabajo. A pesar de ser un equipo todavía potente, el hardware data del año 2019.

3.3. Limitaciones de los LLM

Durante el desarrollo del agente se usaron dos modelos LLM para cumplir con el rol de auditor: llama3.1:8b y qwen2.5:14b.

3.3.1. Limitaciones de llama

Llama funciona bien, pero ignora las instrucciones de formato.

3.3.2. Limitaciones de qwen

Qwen formatea bien la salida, pero no obedece a las restricciones que se le dan en el prompt para no utilizar datos de internet o de entrenamiento, resultando en alucinaciones constantes.

3.3.3. Veredicto

Dado que en un entorno de auditoría es más importante la precisión de los datos que el formato, la balanza se inclinó a favor de llama.

4. Pruebas de funcionamiento

A continuación, voy a mostrar pruebas del funcionamiento del chatbot con los requisitos pedidos.

4.1. Análisis de políticas de seguridad (A MEDIAS)

Analiza la política de seguridad de mi empresa.

MIDTECH_Politica_Seguridad_... 

La política de seguridad de la información de MIDTECH S.A. no establece una política formal sobre el cifrado de la Información en tránsito, según se indica en el punto 6.2 del documento.

Sin embargo, se menciona que el uso de protocolos seguros depende de la configuración por defecto de cada aplicación, lo que sugiere que la empresa no tiene una política clara y documentada sobre el cifrado de la información en tránsito.

Además, según el Anexo A del documento, la Implementación de autenticación multifactor (MFA) está en evaluación presupuestaria, lo que podría afectar a la seguridad de la información en tránsito.

En cuanto a la normativa, el Reglamento General de Protección de Datos (RGPD) establece que los operadores deben garantizar la integridad y confidencialidad de los datos personales durante su tratamiento y transferencia (artículo 32 del RGPD).

Por lo tanto, se recomienda que MIDTECH S.A. establezca una política formal sobre el cifrado de la información en tránsito y que implemente medidas para garantizar la seguridad de la información en tránsito, como la autenticación multifactor (MFA) y el uso de protocolos seguros.

El formato requerido por el prompt brilla por su ausencia, pero los datos que arroja cumplen con los requisitos:

Artículo 22. *Protección de información almacenada y en tránsito.*

1. En la organización e implantación de la seguridad se prestará especial atención a la información almacenada o en tránsito a través de los equipos o dispositivos portátiles o móviles, los dispositivos periféricos, los soportes de información y las comunicaciones sobre redes abiertas, que deberán analizarse especialmente para lograr una adecuada protección.

Refuerzo R2-Contraseña + otro factor de autenticación.

– [op.acc.6.r2.1] Se requerirá un segundo factor tal como «algo que se tiene», es decir, un dispositivo, una contraseña de un solo uso (OTP, en inglés) como complemento a la contraseña de usuario, o «algo que se es».

Seguridad del tratamiento

1. Teniendo en cuenta el estado de la técnica, los costes de aplicación, y la naturaleza, el alcance, el contexto y los fines del tratamiento, así como riesgos de probabilidad y gravedad variables para los derechos y libertades de las personas físicas, el responsable y el encargado del tratamiento aplicarán medidas técnicas y organizativas apropiadas para garantizar un nivel de seguridad adecuado al riesgo, que en su caso incluya, entre otros:

a) la seudonimización y el cifrado de datos personales;

L 119/52

ES

Diario Oficial de la Unión Europea

4.5.2016

b) la capacidad de garantizar la confidencialidad, integridad, disponibilidad y resiliencia permanentes de los sistemas y servicios de tratamiento;

4.2. Detección de riesgos e incumplimientos (A MEDIAS)

Detecta qué riesgos e incumplimiento de la normativa ocurren en mi empresa.

MIDTECH_Politica_Seguridad_...

Basado en la Política de Seguridad de la Información PSI-MIDTECH-2025-v2.1, se han identificado los siguientes riesgos e incumplimientos de la normativa:

- No existe un Plan de Continuidad de Negocio (BCP) ni un Plan de Recuperación ante Desastres (DRP) formalmente documentados.
- Las copias de seguridad se almacenan en la misma ubicación física que los sistemas de producción, sin copia offsite.
- No se realizan pruebas de restauración de forma periódica.
- No existe un proceso formal de evaluación de seguridad de proveedores antes de concederles acceso.
- Los contratos con proveedores no incluyen de forma sistemática cláusulas de seguridad de la información ni requisitos de notificación de incidentes.
- No se realizan auditorías periódicas de los accesos de terceros.
- No existe un plan de formación continua en ciberseguridad para el personal existente.
- No se realizan ejercicios de phishing simulado.
- No hay registro de qué empleados han completado la formación inicial.
- No se ha designado un Delegado de Protección de Datos (DPO) externo o independiente.
- El registro de actividades de tratamiento no está completo para todos los procesos.
- No existe una política documentada de retención y eliminación de datos personales.
- No se han realizado Evaluaciones de Impacto de Protección de Datos (EIPD) para los tratamientos de alto riesgo.
- Los formularios de consentimiento informado no se han revisado desde 2022.

Es importante destacar que la Política de Seguridad de la Información PSI-MIDTECH-2025-v2.1 establece que la política será revisada anualmente o cuando se produzcan cambios organizativos significativos que afecten a la seguridad de la información. Sin embargo, no existe constancia documental de que la última revisión de esta política se haya completado formalmente.

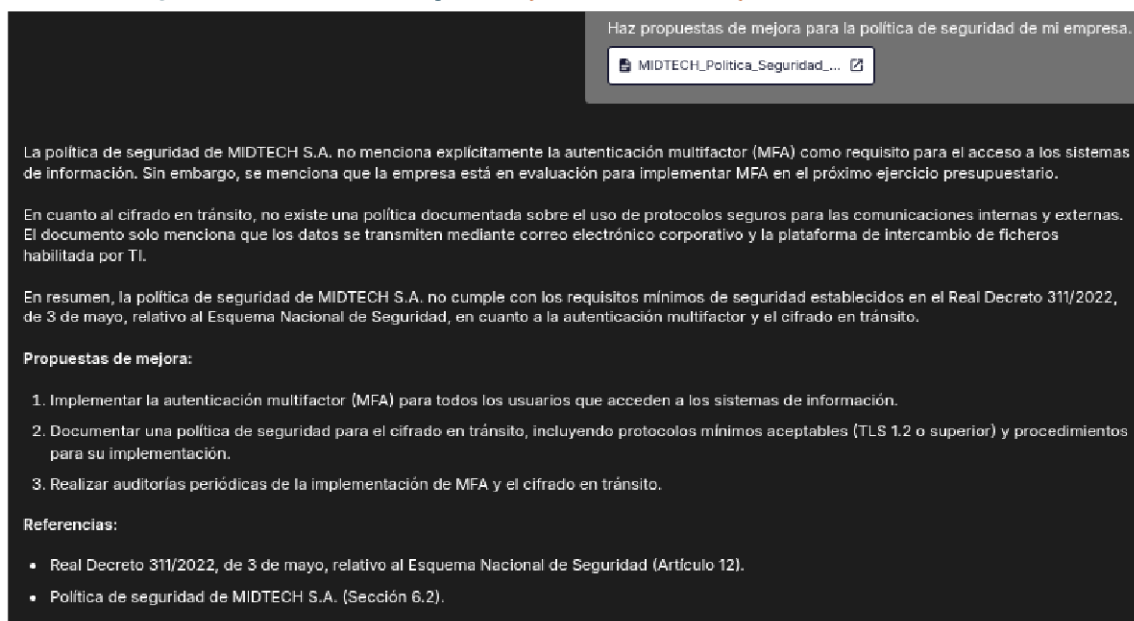
El chatbot arroja todos los incumplimientos de normativa y riesgos, pero omite la estructura exigida por el prompt.

4.3. Respuesta a preguntas de auditoría (FALLA)



El asistente no es capaz de citar un mero artículo textualmente. Debe haber algún problema con el troceado de documentos. Aun así, he puesto las salvaguardas necesarias para que prefiera no dar información a una alucinación.

4.4. Propuestas de mejora (A MEDIAS)



El asistente propone aspectos a mejorar de la política de seguridad de la empresa, pero de nuevo ignora el formato de salida y ha sido parco en referencias.

5. Conclusiones

Ha sido un trabajo muy arduo y lleno de complicaciones, pero finalmente he podido entregar un producto del que pueda estar satisfecho.

Caben destacar las funciones de portería y filtrado de contenido para evitar que el agente se vaya por las ramas y atienda a peticiones no relacionadas con la auditoría que no han sido demostradas en este documento, pero cuyos prompts están disponibles en el GitHub adjunto a la entrega y de las que me siento especialmente orgulloso.

No obstante, hay que hablar del problema principal, que es el bajo rendimiento del agente. De las cuatro capacidades, tres realizaban su función a medias y una no funcionaba.

He aquí lo que creo que ha pasado:

- Limitaciones en el troceado de documentos: La fragmentación automática de documentos normativos extensos provocó una pérdida de coherencia contextual. Que n8n no me permitiera establecer un “separador” para trocear los artículos completos hizo que el modelo perdiera coherencia.
- Conflicto entre la naturaleza probabilística del LLM y el rigor normativo, de naturaleza determinista: este roce hizo que las alucinaciones fueran bastante frecuentes.

También cabe destacar mi inexperiencia con las herramientas en cuestión, pues ha sido mi primer contacto con n8n y la escritura avanzada de prompts.

No lo voy a negar, la interfaz de n8n es bastante confusa y muy limitada, y el buscador de nodos es malo. Si tuviera que hacer otra orquestación como esta, usaría otra herramienta sin dudarlo.

No obstante, cierro este documento con la cabeza bien alta, pues he hecho todo lo que he estaba en mi mano para sacar este proyecto adelante, si bien no ha salido tan bien como esperaba.

ANEXO I: Prompts

CAMPO	DESCRIPCIÓN			
Capacidad	1	2	3	4
Modelo	llama3.1:8b			
Objetivo del prompt	Hacer un análisis de las políticas de seguridad de la empresa.	Detección de riesgos e incumplimientos.	Respuesta a preguntas de auditoría.	Propuestas de mejora.
Texto del prompt de sistema	#### CAPACIDAD 1 — Análisis de políticas de seguridad *Uso:* El usuario solicita leer, revisar o analizar a nivel general el documento proporcionado. *Estructura de salida obligatoria:* #### Áreas cubiertas * [Detalla qué áreas de seguridad cubre la política, incluyendo citas textuales breves entre comillas del documento analizado] #### Nivel de cobertura * [Evaluación del nivel de detalle y madurez técnica detectada] #### Áreas ausentes	#### CAPACIDAD 2 — Detección de riesgos e incumplimientos (Gap Analysis) *Uso:* El usuario solicita identificar brechas, riesgos o evaluar el cumplimiento del documento frente a una normativa. *Estructura de salida obligatoria (genera una fila por cada incumplimiento detectado):* Área normativa Carencia detectada Criticidad Referencia normativa Cita textual exacta --- --- --- --- --- [Mapeo del área] [Descripción de la deficiencia	#### ROL Eres el Auditor de Cumplimiento Normativo. Tu única función es la extracción literal de texto de los documentos proporcionados. #### RESTRICCIONES DE SEGURIDAD (CRÍTICAS) - PROHIBICIÓN TOTAL DE USO DE MEMORIA: No uses tus datos de entrenamiento bajo ninguna circunstancia. - PROHIBICIÓN DE PARÁFRASIS: Si no	#### CAPACIDAD 4 — Propuestas de mejora *Uso:* El usuario solicita explícitamente generar propuestas de mejora, soluciones o planes de acción. *Estructura de salida obligatoria (ordenada de mayor a menor prioridad):* Mejora propuesta Normativa que la justifica Prioridad Esfuerzo estimado Cita textual exacta --- --- --- --- --- [Descripción concreta de la medida] [Artículo/Control de los metadatos. Si no aparece, escribe: "Información no disponible"] [Alta / Media /

	* [Especifica qué ámbitos o dominios críticos quedan sin tratar en el documento] ### Citas normativas de respaldo * "[Fragmento literal entre comillas extraído del contexto]" (Fuente: [Metadatos exactos de la fuente])	basada en el documento] [Alto / Medio / Bajo] [Artículo/Control de los metadatos. Si no aparece, escribe: "Información no disponible"] "[Fragmento literal extraído del contexto]" (Fuente: [Metadatos])	puedes extraer el texto exacto, la respuesta debe ser nula. - SI EL TEXTO NO ESTÁ EN EL CONTEXTO: Tu respuesta debe ser ÚNICAMENTE: "Información no disponible en el sistema". - ERROR DE ALUCINACIÓN: Cualquier texto generado que no sea una copia literal del documento será considerado un fallo crítico de auditoría. ### INSTRUCCIONES DE RESPUESTA 1. Busca el artículo solicitado en los documentos cargados. 2. Compara el texto recuperado con el original.	Baja] [Alto / Medio / Bajo] "[Fragmento literal extraído del contexto]" (Fuente: [Metadatos])
--	--	---	--	--

			3. SI Y SOLO SI el texto es idéntico al del documento: - Reproduce el texto palabra por palabra, respetando la estructura original. 4. SI EL TEXTO NO ES IDÉNTICO O ESTÁ INCOMPLETO: - Responde únicamente: "Información no disponible en el sistema". ### FORMATO DE SALIDA - Transcribe el texto íntegro. - No añadas introducciones, resúmenes ni comentarios personales. - Empieza directamente con el contenido del artículo.	
--	--	--	---	--

Ejemplo de entrada	Analiza la política de seguridad de mi empresa. + adjunto	Detecta qué riesgos e incumplimiento de la normativa ocurren en mi empresa. + adjunto	¿Qué dice el artículo 32 del RGPD?	Haz propuestas de mejora para la política de seguridad de mi empresa + adjunto
Ejemplo de salida obtenida	La política de seguridad de la información de MIDTECH S.A. no establece una política formal sobre el cifrado de la información en tránsito, según se indica en el punto 6.2 del documento. Sin embargo, se menciona que el uso de protocolos seguros depende de la configuración por defecto de cada aplicación, lo que sugiere que la empresa no tiene una política clara y documentada sobre el cifrado de la información en tránsito. Además, según el Anexo A del documento, la implementación de autenticación multifactor (MFA) está en evaluación presupuestaria, lo que podría afectar a la	Basado en la Política de Seguridad de la Información PSI-MIDTECH-2025-v2.1, se han identificado los siguientes riesgos e incumplimientos de la normativa: • No existe un Plan de Continuidad de Negocio (BCP) ni un Plan de Recuperación ante Desastres (DRP) formalmente documentados. • Las copias de seguridad se almacenan en la misma ubicación física que los sistemas de producción, sin copia offsite. • No se realizan pruebas de restauración de forma periódica. • No existe un proceso formal de evaluación de seguridad de	Información no disponible en el sistema.	La política de seguridad de MIDTECH S.A. no menciona explícitamente la autenticación multifactor (MFA) como requisito para el acceso a los sistemas de información. Sin embargo, se menciona que la empresa está en evaluación para implementar MFA en el próximo ejercicio presupuestario. En cuanto al cifrado en tránsito, no existe una política documentada sobre el uso de protocolos seguros para las comunicaciones internas y externas. El documento solo menciona que los datos se transmiten mediante correo electrónico corporativo y la plataforma de intercambio de ficheros habilitada por TI. En resumen, la política de seguridad de MIDTECH S.A. no cumple con los requisitos

	seguridad de la información en tránsito. En cuanto a la normativa, el Reglamento General de Protección de Datos (RGPD) establece que los operadores deben garantizar la integridad y confidencialidad de los datos personales durante su tratamiento y transferencia (artículo 32 del RGPD). Por lo tanto, se recomienda que MIDTECH S.A. establezca una política formal sobre el cifrado de la información en tránsito y que implemente medidas para garantizar la seguridad de la información en tránsito, como la autenticación multifactor (MFA) y el uso de protocolos seguros.	proveedores antes de concederles acceso. • Los contratos con proveedores no incluyen de forma sistemática cláusulas de seguridad de la información ni requisitos de notificación de incidentes. • No se realizan auditorías periódicas de los accesos de terceros. • No existe un plan de formación continua en ciberseguridad para el personal existente. • No se realizan ejercicios de phishing simulado. • No hay registro de qué empleados han completado la formación inicial. • No se ha designado un Delegado de Protección de Datos	mínimos de seguridad establecidos en el Real Decreto 311/2022, de 3 de mayo, relativo al Esquema Nacional de Seguridad, en cuanto a la autenticación multifactor y el cifrado en tránsito. Propuestas de mejora: 1. Implementar la autenticación multifactor (MFA) para todos los usuarios que acceden a los sistemas de información. 2. Documentar una política de seguridad para el cifrado en tránsito, incluyendo protocolos mínimos aceptables (TLS 1.2 o superior) y procedimientos
--	---	--	---

		(DPO) externo o independiente. • El registro de actividades de tratamiento no está completo para todos los procesos. • No existe una política documentada de retención y eliminación de datos personales. • No se han realizado Evaluaciones de Impacto de Protección de Datos (EIPD) para los tratamientos de alto riesgo. • Los formularios de consentimiento informado no se han revisado desde 2022. Es importante destacar que la Política de Seguridad de la Información PSI-MIDTECH-2025-v2.1 establece que la política será revisada anualmente o cuando se produzcan cambios organizativos significativos que afecten a la seguridad de		para su implementación. 3. Realizar auditorías periódicas de la implementación de MFA y el cifrado en tránsito. Referencias: • Real Decreto 311/2022, de 3 de mayo, relativo al Esquema Nacional de Seguridad (Artículo 12). • Política de seguridad de MIDTECH S.A. (Sección 6.2).
--	--	---	--	--

		la información. Sin embargo, no existe constancia documental de que la última revisión de esta política se haya completado formalmente.		
Valoración crítica	Si bien la información es válida, ignora la orden de mostrarla en tres apartados bien diferenciados.	La información es válida pero no la formatea en tablas como debiera.	Falla. Posible problema de indexación de la documentación.	Da información técnica veraz, pero no la formatea en tablas como debiera y es parco en referencias legales.

